

How to Spot and Stop Active Directory Attacks in the Reconnaissance Stage?

 fidelissecurity.com/threatgeek/threat-detection-response/how-to-spot-and-stop-active-directory-attacks-faster

Arad Inbar

May 12, 2023



Listen

[Download PDF](#)

Active Directory (AD) attacks can happen fast. You must be faster.

Once the attacker assumes an AD user account, your chances of detecting them dwindle. They can gain widespread access – even that of an administrator. They can move through systems swiftly and undetected and execute code as if they were the assumed user. By the time you notice any anomalies, it is often too late – the attacker has wreaked havoc, [exfiltrated data](#), or deployed ransomware. You're left to clean up the mess.

In this blog, we will show how, through network monitoring, you can catch attackers who target [Active Directory](#) environments. The best detection techniques catch attackers in the earliest stage possible while [reducing false positives](#). For that reason, we will focus here on catching attackers during the Active Directory Reconnaissance stage, which is an early part of any attack.

LDAP Reconnaissance

By default, any normal AD user in a domain has LDAP (Lightweight Directory Access Protocol) read permissions for that domain.

Thus, a cyber attacker who compromises a domain user (a user who is not a member of a high privileged group such as domain admins) will be able to perform domain reconnaissance for mapping the domain objects. Reconnaissance is a key part of [Active Directory threats](#), as it allows the attacker to map the victim's environment. They can then use that intelligence for lateral movement and privilege escalation.

Active Threat Detection in [Fidelis Network](#)[®] and [Fidelis Elevate](#)[®] connects weak signals that go unnoticed, resulting in strong, evidence-based conclusions automatically. This technology increases the speed and precision of threat detection, uncovering threats that other systems may overlook.

[Active Threat Detection](#) generates high-confidence conclusions by aggregating data from alerts and assets, filtering out noise and false positives to provide security analysts with reliable and actionable insights into the status, location, and impact of threats.

Catch the Threats that Other Tools Miss

- Detect and Correlate Weak Signals
- Active Threat Detection
- Evaluate Findings Against Known Attack Vectors
- Proactively Secure Systems

[Download Now](#)



We will focus on the following LDAP attributes to catch attacker in the active directory reconnaissance stage:

UserAccountControl

The UserAccountControl attribute within Active Directory specifies the configuration of specific account settings. For example: UserAccountControl can indicate disabled accounts or accounts that do not require Kerberos pre-authentication when logging in.

The following list contains all the possible options for UserAccountControl:

Image Source: [Microsoft](#)

We will focus on LDAP queries where attackers look for the following UserAccountControl flags:

- PASSWD_NOTREQD, DONT_REQ_PREAUTH,
- TRUSTED_FOR_DELEGATION,

- ENCRYPTED_TEXT_PWD_ALLOWED.

PASSWD_NOTREQD

When an AD user account has the PASSWD_NOTREQD flag, the account can have an empty password. Attackers will look for those accounts to try without a password. The attacker's goals are to move laterally on the domain and compromise domain accounts. The faster they can achieve that objective, the less likely it is that they'll be detected at this early stage of attack. Logging into these types of AD accounts accelerates the time to infiltration by eliminating the need to discover an account password.

We will flag the following LDAP query as suspicious:

Suspicious LDAP query

DONT_REQ_PREAUTH

When an AD user account has DONT_REQ_PREAUTH flag, the attacker can ask for an encrypted Ticket Granting Ticket (TGT) for the user without providing a password. The TGT is signed with the target user password, allowing the attacker to try brute forcing the password offline. This type of Active Directory attack is known as 'As-Rep Roasting' (MITRE T1558.004).

We will flag the following LDAP query as suspicious:

```
)(userAccountControl:1.2.840.113556.1.4.803:=4194304))
```

Suspicious LDAP query - DONT_REQ_PREAUTH

TRUSTED_FOR_DELEGATION

When an AD computer account has the TRUSTED_FOR_DELEGATION flag set, the computer will save the Ticket Granting Ticket(. An attacker who manages to compromise the computer account will be able to dump KERBEROS TGT tickets for all logged-on users. The attack is known as Pass-the-Ticket. In addition, attackers can use various techniques to force authentication to the victim computer account, for dumping the KERBEROS TGT tickets later.

We will flag the following LDAP query as suspicious:

Suspicious LDAP query - TRUSTED_FOR_DELEGATION

ENCRYPTED_TEXT_PWD_ALLOWED

When an AD user account has the ENCRYPTED_TEXT_PWD_ALLOWED flag set, an attacker who compromises the AD database gains read access to the user account password in a clear text. Typically, these passwords would appear in an NTLM hash format. The clear-text access accelerates an attack by eliminating the need to brute force the password.

We will flag the following LDAP query as suspicious:

Suspicious LDAP query: ENCRYPTED_TEXT_PWD_ALLOWED

Service Principal Name (SPN)

Service Account

A service account is an AD user account created to run a specific service or application. For example, if a SQL service needs access to resources over the domain, a service account with the right access to the resources can be created and used by the service.

AD uses the service principal name (SPN) attribute to differentiate between different services.

Every service account will have an SPN defined representing the specific service it was created for.

KERBEROS Service Tickets

Upon Kerberos authentication, any logged-in user can request the Kerberos domain controller (KDC) for access to any service on the domain. The service is identified by Service Principal Name (SPN).

When an account asks for access to a service on the domain, the KDC returns a service ticket to the client. The service ticket is encrypted with the password hash of the requested domain object hosting the service. For example, when connecting using SSH to a domain computer, the service ticket is encrypted with the domain computer hash hosting the SSH service. An attacker who receives the service ticket can attempt to brute force the hashed password offline.

The password of a machine account is set randomly with a length of 120 characters, whereas passwords of user accounts are usually shorter and often follow predictable patterns. This makes a [brute force](#) attempt on a user password faster and easier than trying to crack a machine account password.

KERBEROASTING ATTACK

The fact that service account has SPN configured, and the fact that any logged-on user can ask for a service ticket in the domain, allowing an attacker who compromise a low privileged domain user to search for service users, ask for a service ticket for them and brute force their password offline. The attack is known as '[KERBEROASTING](#)' (MITRE T1558.003)

An example for a suspicious LDAP query:

Clear Text Passwords

The following LDAP attributes may contain passwords in clear text:

UnixUserPassword

UnixUserPassword is an LDAP attribute for UNIX based systems. Attacker can enumerate the domain for users with UnixUserPassword configured, as it might be saved in a clear text format.

An example for suspicious LDAP query:

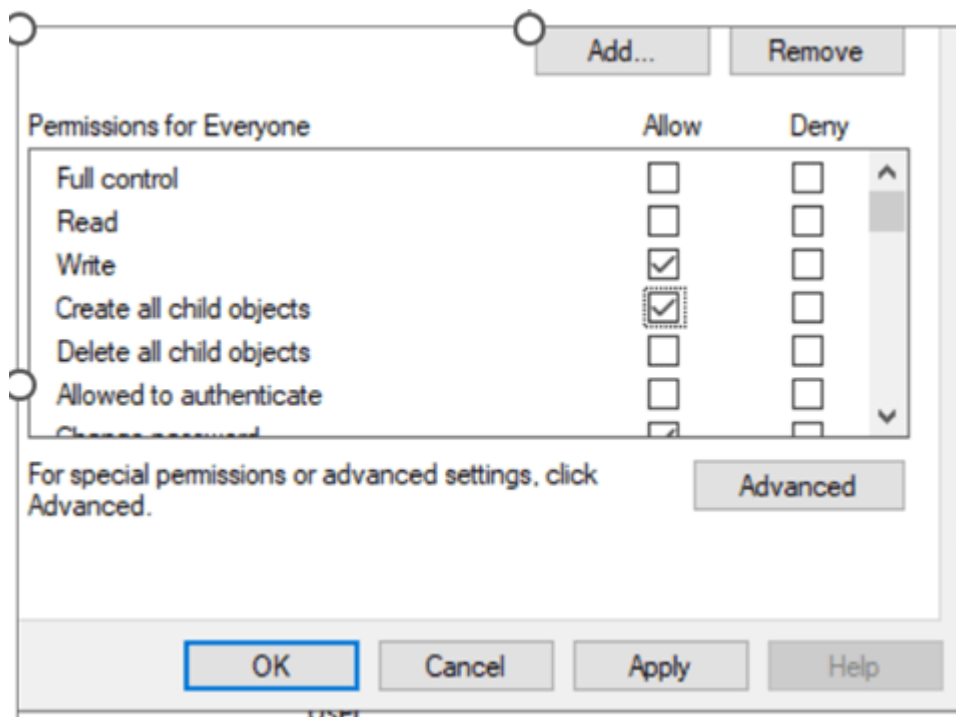
Description

Poorly configured Active Directory environment may contain password in the description:

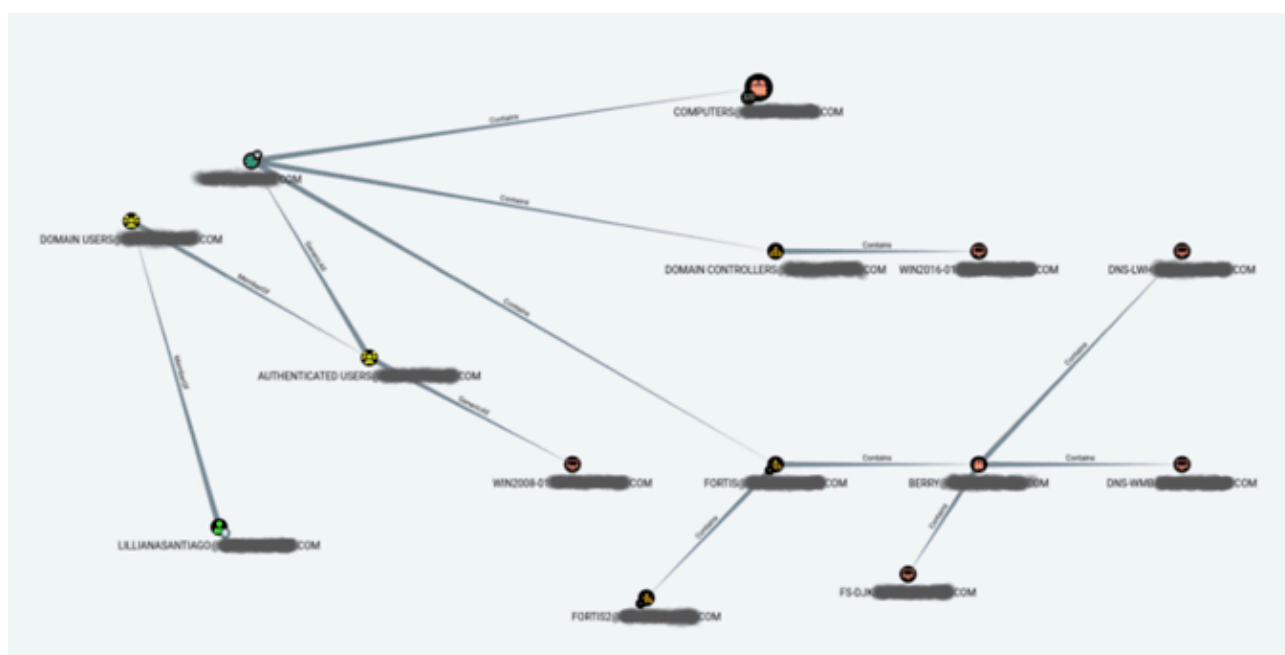
We will flag LDAP queries who look for password in description, for example:

NT-Security-Descriptor

Active Directory uses access control list (ACL) for accounts authorizations.



Knowing the ACLs of accounts in AD will allow attackers to plan their attack for [lateral movement](#) and privilege escalation on the domain, an open-source tool, is using ACL analysis for mapping the possible attacks on a given domain:



AD saves the ACL of an object in 'nTSecurityDescriptor' LDAP attribute.

The 'nTSecurityDescriptor' is divided to 4 parts:

- **Owner** – The owner of the object
- **Group SID (Security identifier)** – The group associated with the object.
- **Discretionary Access Control List (DACL)** – Allow/Deny list for the object:

Permissions Auditing Effective Access				
For additional information, double-click a permission entry. To modify a permission entry, select the entry and click Edit (if available).				
Permission entries:				
Type	Principal	Access	Inherited from	Applies to
Allow	Everyone	Special	None	This object only
Allow	SELF	Special	None	This object only
Allow	Authenticated Users	Read permissions	None	This object only

System Access Control List (SACL) – Auditing permissions for the object:

Owner: Domain Admins (DECTEST2019\Domain Admins) (C)

Permissions Auditing Effective Access

For additional information, double-click an audit entry. To modify an

Auditing entries:

Type	Principal	Access
 Succ...	Everyone	
 Succ...	Everyone	

An attacker who compromises a low privileged AD user will not have permission to the SACL part of the security descriptor. The DACL is the most important part of the descriptor, from the attacker perspective, as it identifies authorized actions the object can perform within the domain. To get the DACL part on the security descriptor using LDAP, the attacker must specify what part of the descriptor they are interested in. LDAP uses a control named 'LDAP_SERVER_SD_FLAGS_OID' that controls which part of the descriptor can be retrieved.

The following flags describe the different possible descriptors:

Bit flag name and value	Portion of security descriptor to retrieve/update
OWNER_SECURITY_INFORMATION (OSI) 0x1	Owner identifier of the object .
GROUP_SECURITY_INFORMATION (GSI) 0x2	Primary group identifier.
DACL_SECURITY_INFORMATION (DSI) 0x4	Discretionary access control list (DACL) of the object.
SACL_SECURITY_INFORMATION (SSI) 0x8	System access control list (SACL) of the object.

Image Credit: [Microsoft](#)

To catch cyber attacker who performs ACL analysis using LDAP, we will monitor requests for the nTSecurityDescriptor object with one of LDAP_SERVER_SD_FLAGS_OID.

For example, we can identify an attacker who asks for the DACL only:

```
  ▾ attributes: 1 item
    AttributeDescription: nTSecurityDescriptor
  [Response In: 509]
  ▾ controls: 1 item
    ▾ Control
      controlType: 1.2.840.113556.1.4.801 (LDAP_SERVER_SD_FLAGS_OID)
      criticality: True
      controlValue: 3003020104
```

Conclusion

Threat actors continuously innovate, creating new and novel techniques to gain access to confidential information. Reconnaissance is a key part of any Active Directory attack, as it allows attackers to map the victim's environment and gather intelligence for lateral movement and [privilege escalation](#).

Applying detection rules helps catch the attackers early on, before any damage is done. To keep your organization safe, it's important to ensure your systems are up to date, and that you have installed an automated detection system, such as [Fidelis Elevate](#)[®]. It offers [active directory security](#) along with endpoint, network and [deception security](#), to proactively defend against cyber-threats and active attacks.

Don't wait - Secure your Active Directory against Threats

See why security teams trust Fidelis to:

- Cut threat detection time by 9x
- Simplify security operations
- Provide unmatched visibility and control

[Book a Demo Now!](#)

Active Threat Detection, a key component of the Fidelis Elevate platform, automatically correlates weak signals that go ignored, resulting in robust, evidence-based conclusions. This revolutionary technology increases the speed and precision of [threat detection](#), revealing threats that other systems may overlook.

To stay up to date on the [latest threat research](#) and industry insights, subscribe to our [Cybersecurity blog](#) from the professionals at Fidelis Security.

One Platform for All Adversaries

See Fidelis in action. Learn how our fast and scalable platforms provide full visibility, deep insights, and rapid response to help security teams across the World protect, detect, respond, and neutralize advanced cyber adversaries.

[Get a Demo](#)